

Cedar Bridge payroll processing agreement

Synthetic portfolio contract between Northstar Labs, the customer, and Cedar Bridge Operations, the supplier. Neither party represents a real organization. Effective date: 1 October 2026. This text is designed to test retrieval of agreed service boundaries and qualifications; it is not legal advice or an executable commercial instrument.

1. Contract documents and interpretation

The agreement covers payroll preparation for Northstar's European workforce. It includes the signed service schedule below, four incorporated Northstar supplier standards and the executed change schedule at the end of this file. The final change schedule prevails over inconsistent deadlines in the supplier standards for the specifically named activity. Silence in that schedule does not waive unrelated requirements. An internal sales presentation or an unsigned implementation estimate cannot change an obligation in the executed documents.

Production payroll means the tenant that receives employee identifiers, bank routing details, salary components and approved adjustments. It excludes the supplier's training tenant, demonstration dataset and corporate billing records. A person reading the agreement should establish which population a statement concerns before comparing numerical commitments. Several operating tasks occur after termination, and a delivery deadline must not be confused with a deletion deadline. The chronology in the final change schedule is part of the agreed service definition.

The customer appoints its Payroll Operations Lead as the instruction owner. The supplier appoints a named service manager and deputy in the private contact register. Those names are deliberately absent from this synthetic document. An instruction is authenticated through the service desk and linked to the customer's tenant; an email from an unknown address is not an instruction to disclose or remove employee records. The supplier records conflicting instructions and seeks clarification rather than choosing the instruction with the earliest timestamp.

2. Administrative identities

Cedar requires a second authentication factor for every human administrator entering the production payroll console. This includes supplier support personnel using a temporary elevated role. Access requests identify the maintenance task, tenant and approving service owner. Session records distinguish approval from the moment the

entitlement becomes active. Employment termination triggers revocation independently of the periodic review calendar.

Non-interactive payroll connectors are excluded from the human MFA rule and instead use scoped credentials rotated at least every 45 days. The inventory explicitly classifies an identity as a human account or a connector; an operator cannot avoid the second factor by relabelling their ordinary login. Connector permissions are restricted to the integration endpoints stated in the interface register. The rotation record includes the replacement date and confirmation that the retired credential no longer succeeds. The customer manages its own ordinary payroll-user assignments.

3. Storage and removal

The ordinary contract rule requires removal of production payroll records within 30 days after service termination. Removal includes working replicas and job outputs that remain available to the application. The supplier confirms the tenant and removal trigger before initiating the workflow. Northstar can request a completion receipt listing the stores processed, the completion date and any outstanding preservation exception. An outstanding exception is reported rather than silently treating partial removal as complete.

Encryption covers production payroll databases, their replicas, event logs and disaster-recovery copies. The customer does not receive raw encryption keys through an assurance request. Instead the supplier provides a configuration description and a sample of access-control evidence. The inventory distinguishes the key-administration role from the role that reads ordinary payroll output. Change approval is recorded before a component moves to a different storage class.

Diagnostic CSV exports containing employee records are included in the encryption obligation even when their intended lifetime is less than one working day. An export created for a support task has a task owner and a removal instruction. A file copied to a personal workstation is outside the approved diagnostic route. The supplier may demonstrate the route using synthetic data, but that demonstration is not independent evidence of every past support task.

4. Incident escalation

Cedar sends the first payroll incident notice within 18 hours after a credible service-impact signal reaches the designated response channel. Initial facts may be incomplete. The notice names the assessed service,

describes known impact and provides the next update route. It must not imply that the absence of a completed investigation proves there was no impact. The supplier records later corrections without erasing the initial observations.

Waiting for root-cause confirmation does not postpone the start of the 18-hour notification period. The response lead distinguishes a potential impact signal from a routine application warning with no service consequence. Escalation decisions remain available for review. A customer request for an additional update does not reset the initial deadline. The parties can coordinate communications through their named contacts without treating that coordination as permission to suppress a notice.

5. Location and support boundary

Primary payroll storage and routine calculation take place in Germany and Ireland. The architecture register names the production database, processing queue and approved recovery location. Office addresses are not substituted for component locations. Relocation of a production component follows the change procedure and is not implied by adding a new supplier employee.

The original support schedule limits human access to personnel working in the European Economic Area. A later change can authorize another support route only when the customer approves its scope and safeguards. The contractual location of the supplier's parent entity is not itself evidence of where records are viewed. Northstar's privacy reviewer assesses the actual access path, record categories and duration together.

6. Changes to delivery partners

Cedar gives 20 calendar days of advance notice before adding a delivery partner with access to payroll records. The notice names the activity, location, data categories and proposed start date. A marketing reseller with no access to the service is not treated as a payroll delivery partner merely because it signs a referral agreement. Objections identify a concrete concern for the assessed activity and enter the contract-change register.

An emergency replacement following insolvency may start immediately, but Cedar must notify Northstar within two working days and supply the same access details. This exception does not remove the need to record the replacement, verify its controls or address the customer's objection. The supplier remains accountable for the authorized work and cannot treat the partner's own template as a unilateral amendment to this agreement.

7. Service levels and planned exercises

The recovery target for the production payroll tenant is six hours from declaration of a service disaster. The declaration is a recorded operational event, not the time at which an individual employee first reports a login problem. The recovery plan identifies processing dependencies, customer validation steps and the role authorized to declare ordinary operation restored. A successful infrastructure restart alone does not demonstrate that a payroll run has reconciled correctly.

The six-hour target does not apply to the quarterly payroll simulation environment, whose restoration is scheduled on a best-effort basis. That environment contains synthetic records and is separated from production processing. An exercise report must state which environment was tested, the start trigger and the validation performed. Northstar should not compare the duration of a training exercise with the production recovery target without checking those boundaries.

8. Assurance and inspection

Cedar's available independent assurance report covers the established payroll processing platform for January through December 2025. A register entry identifies the report and its scope; the underlying report is supplied through an authorized review route. The supplier must disclose known exclusions rather than present a company certificate as proof that every acquired component is assessed. Northstar can request supporting declarations while deciding whether independent coverage is adequate.

The independent report excludes the connector acquired in February 2026; its extension assessment is scheduled and has not yet been completed. Operational monitoring and internal testing of that connector are useful evidence but do not alter the report's stated period. The customer records its decision about compensating measures separately from the supplier's target date for finishing the extension. A planned assessment is not a completed assessment.

9. Billing, acceptance and exit coordination

The monthly charge separates production processing capacity, approved implementation work and optional training sessions. The customer may challenge an item by identifying the relevant order and disputed amount; the service manager records the response. An invoice dispute does not itself authorize disclosure of employee records to the billing team. Purchase-order identifiers are retained in corporate records under their

own schedule and do not replace the service's removal obligations.

Acceptance of the initial interface confirms that the agreed synthetic test records pass the reconciliation procedure. It is not acceptance of every future file and does not release the supplier from reporting a later control failure. Material interface changes require an updated test plan with the customer. A change in an external banking endpoint can require a joint transition plan without amending the definition of production payroll data.

On termination Cedar makes a tenant-specific payroll export available for customer validation. The export includes the documented field map and record counts. Northstar confirms whether the package can be used in its receiving system; availability of a download link is only one step in that process. The change schedule below fixes the delivery window and describes what may remain after validation. Termination of processing and closure of a billing account are separate events.

Incorporated annex 1

Third-Party Security Incident and Resilience Standard

Synthetic portfolio demonstration; not legal advice or a statement of any real organization's practices. Northstar Labs and all named suppliers are fictional.

Owner: Security Incident Response Lead. Approver: Northstar Risk Committee. Version: 1.0. Effective: 2026-09-15. Review due: 2027-09-15. Policy set: Northstar Labs Third-Party Assurance Standard.

1. Purpose, applicability and event definitions

This document establishes a usable incident interface between Northstar and an assessed supplier. The four identified IR controls are the supplier obligations in this document. Other paragraphs explain those controls and assign Northstar work. They do not add unlisted counterparty requirements. Incident preparation is assessed for every relationship, even before any event has occurred. The duties described by each control operate when the qualifying event arises; assessing preparedness does not imply that an incident has already occurred.

A qualifying incident is a suspected or confirmed event affecting the confidentiality, integrity or availability of Northstar data, systems, credentials or service delivery. It includes credible indications of unauthorized access, misuse of an operational identity and material

disruption within the assessed service boundary. A general news article about an unrelated platform is not evidence that this supplier has suffered such an event. Northstar's Incident Commander determines the internal triage route using the known service dependency and available facts.

Awareness is the point at which the supplier becomes aware of the qualifying incident, rather than the time at which its investigation reaches a final conclusion. Calendar hours include nights and weekends. An initial notice is a first communication of known facts; an update adds or corrects information as investigation proceeds. A confirmed incident supports a scoped root-cause report, while an initial suspicion can close with a documented explanation of why the suspected impact was not established.

2. Precedence and preparation

This document owns the initial notification clock. The privacy document governs ordinary deletion requests, and the governance document governs continuity and exit planning. An incident preservation need can affect data handling, but it does not silently replace the privacy exception process. Northstar Security and Privacy must coordinate any preservation decision and document its basis. Reviewers retain the applicable sources so a later analysis can distinguish an incident-specific restriction from a general service retention practice.

Northstar's Business Owner must identify the service dependency and available fallback before relying on an incident contact. The Incident Commander must maintain Northstar's own monitored intake route and escalation responsibilities. A supplier can send a timely notice that Northstar mishandles internally; the assessment should not confuse these separate actors. Northstar teams must test that the internal recipient can reach Security, Privacy and the Business Owner without relying on one individual's availability.

A preparation review can inspect the supplier's escalation route, sample notice structure and exercise records. These materials demonstrate planned arrangements to different degrees. A contact list supports reachability but does not show how a real event was handled. An exercise record shows what was tested, including the assumptions and simulation limits. Northstar Third-Party Risk must preserve those distinctions in the evidence record rather than treating any document with incident in its title as complete assurance.

3. Initial notice and the clock

IR-01 - Severity: High. Applies to qualifying incidents in every relationship.

The supplier must notify Northstar within 24 calendar hours after becoming aware of a suspected or confirmed incident affecting Northstar data, systems, credentials or service delivery.

The first notice can be incomplete. Useful known facts include the affected service, detection time, nature of the suspected impact, immediate containment steps, contact route and areas still under investigation. The absence of a confirmed cause does not delay the initial notice. Northstar Security must distinguish a supplier's stated notification commitment from evidence that a particular historical event met it. A declared number of hours can establish the promised notice window, while an event assessment needs the actual awareness and communication timestamps.

A notice timestamp and an awareness timestamp refer to different points. Discovery by a third party, automated alert creation and human triage may also differ. Northstar's Incident Commander must ask the supplier to explain the relevant chronology when assessing a real event. A correction to an earlier estimate is retained with its reason. It does not erase the earlier communication or justify changing the clock to the date of a final executive briefing.

Northstar Privacy must determine whether an event raises separate communications or notification questions for Northstar. Those internal duties are not outsourced to the supplier by this standard. The supplier notice provides information for that decision; it is not a substitute for it. Procurement must preserve any contractual incident schedule that sets a stricter commitment, while Security records how that commitment relates to the operational baseline used in the current assessment.

4. Evidence and investigation timeline

IR-02 - Severity: High. Applies to qualifying incidents in every relationship.

The supplier must preserve relevant incident evidence and maintain a timestamped timeline of observations, containment actions and recovery decisions affecting Northstar.

Relevant evidence can include audit records, operational events, configuration snapshots and investigation notes. Preservation does not

mean distributing unrestricted copies to every participant. A review can establish what was preserved, who controlled it and how its integrity was maintained. Northstar Security must use an appropriate channel for sensitive material and request only what is needed to understand the impact. Production secrets and unrelated customer content are not appropriate attachments to a general assurance ticket.

A useful timeline distinguishes observation from inference. An operator may observe a failed login, infer a possible misuse route and later reject that hypothesis. Each item has a time reference and an identified source or decision owner. Northstar's Incident Commander must retain unresolved uncertainty in the case record. A neat narrative written after closure can omit important decision points; the evidence assessment considers whether the record supports the stated sequence and service impact.

Preservation also interacts with routine deletion and log rotation. Northstar Security and Privacy must document why relevant material is isolated and when the preservation decision is reviewed. The exception identifies affected data categories and access boundaries. It is not permission to keep all records indefinitely for unspecified investigations. The privacy standard's ordinary deletion rule continues to describe the normal service commitment outside the documented incident-specific boundary.

5. Containment, recovery and communication

IR-03 - Severity: Medium. Applies to qualifying incidents in every relationship.

The supplier must provide containment and recovery updates to Northstar through incident closure, including material changes to assessed impact and unresolved recovery risks.

Updates explain what changed since the previous communication and what remains unknown. A fixed update cadence can be agreed during triage according to event severity and operational need. This standard deliberately does not create an additional universal interval in hours. Northstar's Incident Commander must record the agreed cadence and the route for urgent changes. Silence is not evidence that recovery has completed, and a status page may omit information specific to Northstar's service scope.

Containment can interrupt service while limiting harm. Northstar's Business Owner must participate in decisions affecting its own operations and fallback arrangements. A supplier's technical action and Northstar's

business decision remain separate records even when they happen in the same meeting. Reviewers look for a coherent explanation of the chosen action, expected effect, observed result and remaining exposure. Containment quality depends on the event context and the observed results, which Security evaluates with the Incident Commander.

Recovery readiness depends on the affected boundary. A restored user interface may coexist with delayed background processing or unavailable administrative tooling. Northstar Security must ask what was tested before the service was described as recovered. The Business Owner must validate the operational outcome relevant to Northstar. A declaration that all systems are healthy is useful only when its scope and observation period are clear. Independent technical evidence can strengthen that understanding without removing the need for a human decision.

6. Root cause and corrective action

IR-04 - Severity: Medium. Applies to confirmed incidents in every relationship.

For confirmed incidents, the supplier must deliver a scoped root-cause and corrective-action report identifying contributing factors, accountable remediation owners and verification of closure.

A scoped report explains the affected service and evidence limitations. Root cause may involve several contributing conditions rather than a single person or failed component. Corrective actions address those conditions and identify how completion is checked. Northstar Security must distinguish an action being assigned, an action being implemented and an action being verified. A future target date is not a completed control, and a generic training promise may not address the technical route that caused the incident.

The report can preserve uncertainty where a definitive cause is unavailable. In that case the review asks whether the remaining uncertainty changes the service decision or calls for additional controls. Northstar Third-Party Risk must link significant corrective actions to the supplier's open assurance record. A closed incident ticket does not automatically close a separate risk exception. Conversely, an incident outside the assessed boundary should not be represented as proof that a Northstar-specific requirement failed.

7. Exercises and internal lessons

Northstar's Incident Commander must conduct an internal lessons review

after material events and maintain the readiness of the intake and escalation process. High-criticality service exercises are considered with the continuity and exit obligation in the governance document. The supplier exercise narrative is evidence for that existing obligation rather than a fifth incident control. A walkthrough can demonstrate role coordination, while a recovery test can demonstrate a technical outcome; the review records which kind occurred.

Useful scenarios expose a boundary, such as the primary contact being unavailable, an uncertain personal-data impact or a restore that reintroduces deleted records. Northstar teams must identify their own improvement actions and owners. An exercise is not a prediction that an actual event will unfold identically. The assessment uses it as evidence of preparation and as a way to find unresolved dependencies before a time-critical decision is needed.

8. Exceptions and records

The Security Incident Response Lead approves documented, time-bound exceptions to incident preparation or evidence arrangements after consulting Privacy and the Business Owner. Northstar Third-Party Risk must record compensating controls, responsible owners and reassessment before expiry. An exception never delays the initial notice while facts remain incomplete. Any proposed contractual change to the notification commitment is escalated for a new policy and relationship decision rather than hidden as an informal operational practice.

Northstar must retain the source version, evidence provenance, chronology and human decisions needed to reconstruct the review. New evidence can justify a new analysis without rewriting the earlier report. The review record keeps residual risk, evidence gaps and reviewer disposition separate. A satisfactory declared notice window does not close unresolved questions about investigation or recovery capability. Security retains those questions until an accountable owner resolves them.

Incorporated annex 2

Third-Party Information Security Standard

Synthetic portfolio demonstration; not legal advice or a statement of any real organization's practices. Northstar Labs and all named suppliers are fictional.

Owner: Head of Information Security. Approver: Northstar Risk Committee.
Version: 1.0. Effective: 2026-09-15. Review due: 2027-09-15. Policy set:

Northstar Labs Third-Party Assurance Standard.

1. Purpose, applicability and definitions

This standard describes the security baseline for assessed technology relationships. Its purpose is to make the boundary between a supplier's service and Northstar's own configuration visible before either party relies on the other. The six identified SEC controls below are the supplier obligations in this document. Other paragraphs explain those controls or assign internal Northstar responsibilities; they do not add unlisted supplier obligations. A missing document is a reason to request evidence, not evidence that a control operates or fails.

The baseline addresses technology suppliers storing Northstar data or accessing Northstar systems. The assessment records purpose, shared data, system access and business criticality in the relationship context. Conditional controls distinguish personal-data processing, privileged access and high business criticality. The encryption baseline in this standard applies to relationships involving personal data. The access lifecycle control is limited to relationships with privileged access. Security reviewers consider other data and access arrangements manually before approving the relationship.

Northstar data means information supplied by Northstar or produced for it through the assessed service. A privileged account can alter service configuration, grant access, inspect protected records or bypass ordinary user restrictions. Supplier personnel includes employees and authorized contractors acting under the supplier's direction. A declaration describes what a supplier says; independent evidence describes work performed by an assessor outside the operating team. Neither label guarantees truth, coverage or freshness.

2. Precedence and shared responsibility

This document forms one standard with the privacy, governance and incident documents. The privacy document defines the end-of-service deletion trigger; the incident document defines the initial notification clock. Security terminology does not replace those definitions. Where a contractual schedule appears inconsistent, Northstar Security and Procurement must record the conflict, identify the binding agreement and obtain an owner decision before treating the policy as satisfied. Reviewers do not infer an exception from silence or from a previous approval.

The Business Owner must describe the architecture boundary, including

customer-managed configuration, supplier infrastructure and shared operational tasks. For example, a customer may control ordinary user invitations while a supplier controls its support accounts and storage keys. A diagram is useful only when it names who operates each component and identifies which environment it represents. Marketing diagrams often omit administrative paths. Northstar Security must compare the diagram with the access description instead of assuming that a hosted service has no access to customer records.

3. Ownership and inventory

SEC-03 - Severity: Medium. Supplier accountability for security.

The supplier must name an accountable security owner and maintain a current inventory of controls and assets supporting the assessed service.

The owner can be a role backed by a monitored address; publishing a personal telephone number is unnecessary. The inventory explains the production boundary, supporting identity services, operational tooling and material dependencies. Evidence can include a dated ownership statement and a scoped asset register with sensitive identifiers redacted. The useful question is whether an operator can identify what protects this service and who resolves an exception, rather than whether a long spreadsheet exists.

Northstar Third-Party Risk must record the evidence date, service name, coverage period and declared author. A generic enterprise control catalogue may establish intent without demonstrating service coverage. When a supplier has acquired a business or replaced an operational platform, Northstar Security must check whether the inventory reflects that change. A pending update remains visible in the review record and is assigned to an owner with a due date.

4. Identity and privileged access

SEC-01 - Severity: High. Applies when privileged access is present.

For relationships with privileged access, the supplier must enable MFA for every privileged account, including supplier support accounts accessing Northstar systems or the assessed service.

This baseline includes interactive administrative paths and support escalation paths. MFA means multi-factor authentication using distinct factor categories. A protected ordinary user login does not establish that a separate administrative interface has the same protection. Northstar

Security must ask which account populations and authentication paths the declaration covers. Evidence may describe the identity provider, enforcement policy, enrollment coverage and treatment of emergency access without disclosing recovery secrets.

SEC-04 - Severity: High. Applies when privileged access is present.

For relationships with privileged access, supplier personnel must receive approved least-privilege access and have that access revoked promptly when their duties change or end.

Least privilege means access proportionate to an approved operational task. Prompt revocation is intentionally a contextual obligation rather than an invented universal number of hours. Useful records include an access request, approving role, effective entitlement and a completed removal example. A monthly review does not alone prove that a departure was handled when it occurred. Northstar reviewers distinguish preventive approval, event-driven removal and periodic reconciliation; each addresses a different failure mode.

Northstar's own administrators must configure the customer side of the service according to the agreed responsibility record. Supplier operation of an identity platform does not relieve Northstar of managing its own joiners and leavers. When a shared account is encountered, Security must establish its purpose and traceability before deciding whether evidence supports the access control. An exception has a named approver, compensating measures and an expiry; it is not hidden inside a favorable questionnaire answer.

5. Data protection and keys

SEC-02 - Severity: High. Applies when personal data is processed.

For relationships processing personal data, the supplier must keep Northstar data encrypted at rest across production storage, replicas, logs and backups.

The assessed boundary includes derived service records containing Northstar data. A production database statement alone leaves replicas and operational exports unexplained. Key management information helps reviewers understand who can decrypt records, how access is separated from routine application operation and how recovery is controlled. An encryption declaration establishes the stated storage protection; reviewers separately consider algorithm choice, implementation assurance and key-management practices.

Northstar Security must request an architecture explanation when data passes through temporary stores, analytics pipelines or support attachments. Redacted configuration evidence may show enforcement without revealing key material. Transport security and secrets handling belong in the architecture review as contextual considerations; this document does not introduce additional numbered supplier controls for them. If a storage component falls outside the declared boundary, the reviewer records that limit rather than broadening the declaration by assumption.

6. Vulnerabilities, development and change

SEC-05 - Severity: High. Vulnerability management.

The supplier must operate a documented vulnerability and patch process that prioritizes remediation using severity, exposure and service impact, including testing, change approval and tracked exceptions.

A useful process identifies intake sources, triage responsibility and the route from a finding to a deployed correction. Public exposure can make a moderately scored weakness urgent; a severe issue in an unreachable test component may call for a different response. This standard deliberately avoids a universal patch deadline. Northstar Security must examine whether the supplier can explain its prioritization and show the disposition of a meaningful sample rather than merely quote a policy title.

Testing and approval may be implemented through a controlled deployment pipeline, review gates or an emergency-change procedure. Separation between author and approver can reduce accidental release risk, but a checkbox does not establish that the gate cannot be bypassed. Reviewers look for a coherent example connecting a finding, risk decision, test result and deployment record. When an urgent repair bypasses a normal step, the relevant evidence includes the recorded reason and follow-up review under the same process.

Development practices, logging and monitoring provide context for that assessment. A supplier can use code review, dependency scanning, runtime detection and operational alerts to find weaknesses at different stages. Northstar Security must avoid interpreting a list of tools as proof that findings are resolved. Redacted samples can explain how an alert reaches an accountable operator and how the operator records closure. Detailed exploit payloads and production credentials are inappropriate review attachments.

7. Independent assurance and recovery context

SEC-06 - Severity: Medium. Applies when business criticality is high.

For high-criticality services, the supplier must provide current independent assurance evidence identifying the assessed service, covered controls, review period and material exclusions.

An independent report is useful only within its stated scope. A certificate may identify a management system while omitting the product under review. A report may cover the production platform but exclude a newly acquired support portal. Northstar Third-Party Risk must retain the exclusion in the assessment and seek an explanation of the uncovered service path. Describing a document as independent does not make every statement in a supplier-authored summary independently verified.

Backup and restoration practices provide context for the continuity obligation in the governance document. Evidence can identify recovery objectives, dependencies and a completed restore exercise. A backup exists to support a recovery outcome; its mere existence does not prove a usable restore. Northstar's Business Owner must explain the impact of service loss so Security can assess whether the evidence addresses the relationship's actual needs. The governance control remains the single supplier obligation for continuity and exit planning.

8. Review records and exceptions

Northstar Security must record the control, missing evidence, assessed impact, compensating measures, proposed expiry and responsible owner for each exception. The Head of Information Security approves security exceptions after consulting Privacy where personal data is involved. Northstar Third-Party Risk must schedule reassessment before expiry and keep the previous record available for comparison. Acceptance of residual risk is a human decision bound to the assessed service and policy version, not a change to the quoted source.

The review record distinguishes a supplier declaration, independently examined material and Northstar interpretation. Evidence freshness follows the service's change history and stated coverage period, not the date on which a file was uploaded. An old report with a recent filename remains old evidence. When the supplier cannot disclose a sensitive report, Northstar may arrange restricted review and record its actual scope; absence of a public copy does not justify inventing findings. These records support an accountable decision without presenting the assessment as a security certification.

Third-Party Privacy and Data Handling Standard

Synthetic portfolio demonstration; not legal advice or a statement of any real organization's practices. Northstar Labs and all named suppliers are fictional.

Owner: Privacy Lead. Approver: Northstar Risk Committee. Version: 1.0. Effective: 2026-09-15. Review due: 2027-09-15. Policy set: Northstar Labs Third-Party Assurance Standard.

1. Purpose, applicability and vocabulary

This document governs relationships in which personal data is processed. Its six identified PRI controls describe the supplier-facing baseline. The remaining paragraphs provide operational interpretation and Northstar responsibilities. They do not create additional supplier controls. The baseline is an internal assessment standard for the fictional organization, not a statement that every legal obligation has been captured. Northstar Privacy must determine the relevant legal and contractual context before approving an actual processing arrangement.

Personal data is information relating to an identifiable person in the assessed relationship. The relationship description records the intended purpose, categories of shared data and system access, and the importance of the service. Processing includes ordinary service operation and authorized support activity. A subprocessor performs processing for the supplier; a location can describe storage, routine computation or remote access, and those concepts are not interchangeable. A declaration is supplied by the counterparty, while independent evidence describes work performed outside its operating team.

Documented instructions are the authorized purposes and handling directions agreed for the assessed service. A deletion trigger is termination of that service or an authenticated deletion request from Northstar. Calendar days include weekends. An authenticated request is verified through the agreed channel before destructive action starts. Northstar Privacy must distinguish a valid request from a message whose sender or scope is uncertain, without allowing internal administrative delay to rewrite an agreed trigger.

2. Precedence and responsibilities

The information security document defines the encryption baseline, the

governance document defines relationship ownership and the incident document defines initial incident notice. This document controls the interpretation of the deletion window and primary hosting location. Northstar Procurement must bring inconsistent schedules to Privacy before contract approval. Reviewers retain both conflicting source passages rather than silently selecting whichever gives a favorable result. A human owner resolves applicability and records the basis for the decision.

Northstar's Business Owner must map the intended data flow before sharing records. That map identifies collection, service use, routine output, support access and end-of-service handling. Privacy must compare the proposed purpose with the actual service configuration. For example, a contact directory used to send product notices differs from a dataset reused to train a supplier product. A vague description such as customer data hides the distinction and is insufficient for the internal review.

3. Processing agreement and instructions

PRI-01 - Severity: High. Applies when personal data is processed.

For relationships processing personal data, the supplier must have a signed DPA with Northstar before processing begins.

DPA means data processing agreement. The signed schedule identifies the assessed service and the parties acting in the arrangement. A supplier's public template can support negotiation but is not the same as an executed agreement. A signed-state declaration is the starting point for examining the service scope, date, signatories and schedules. Privacy determines the parties' roles and reviews the relevant contractual provisions.

PRI-05 - Severity: High. Applies when personal data is processed.

For relationships processing personal data, the supplier must process Northstar data only for documented purposes and minimize the data used to what those purposes need.

The purpose record describes the service outcome, categories involved and any operational access needed to deliver it. Minimization can concern fields, granularity, recipient groups or storage duration. Removing direct identifiers may reduce exposure while leaving indirect identification possible. Northstar Privacy must assess the proposed dataset in context rather than treating a masking label as proof that it contains no personal data. Worked samples should use synthetic values instead of copying customer records into assurance attachments.

A change from generating aggregate usage statistics to building user profiles changes the review question even if the infrastructure is unchanged. Northstar's Business Owner must raise such a change before expanding the use case. Privacy must record whether revised instructions, a new assessment or additional controls are needed. This internal change review explains the existing purpose-limitation control; it does not create a separate supplier obligation hidden in narrative text.

4. Locations and remote access

PRI-03 - Severity: High. Applies when personal data is processed.

For relationships processing personal data, the supplier must keep primary hosting and processing for the assessed service in the EU.

The hosting baseline concerns the assessed service's primary storage and routine computation. It is not a shortcut for evaluating every remote-access arrangement. A US support subprocessor can raise a question about transfer scope without changing the declared primary hosting region. Northstar Privacy must ask what records can be accessed, for what task, under whose authorization and with which safeguards. The presence of a US organization in a list is not by itself evidence that the primary platform is hosted there.

The service boundary includes production replicas when they participate in normal processing. An architecture narrative can explain exceptional recovery locations and the conditions under which they are used. Reviewers record any unresolved boundary separately instead of assigning a region to components the evidence does not describe. Location names in corporate addresses, legal notices or billing details do not establish where this service processes data. Exact quotes and source locations make these distinctions reviewable.

5. Subprocessor inventory and change review

PRI-04 - Severity: Medium. Applies when personal data is processed.

For relationships processing personal data, the supplier must maintain a current subprocessor inventory and give Northstar advance notice of changes so Privacy can review access scope and transfer safeguards.

An informative inventory names the entity, service function, access category and operating locations. Broad labels such as infrastructure or support can conceal materially different capabilities. A supplier can describe whether an operator sees customer content, pseudonymous telemetry

or only a contact address. Northstar Privacy must compare the inventory with the architecture and the signed schedule. An omitted dependency remains a review gap even when another supplier entity holds a broadly worded certification.

Advance notice supports a decision before the changed processing takes effect; this standard intentionally does not invent a universal numerical notice period. The contractual schedule can specify a period appropriate to the relationship. Northstar Procurement must preserve that schedule with the review record. Privacy must document approval, conditions or an objection and identify the operational response if a change cannot be accepted. Privacy reviews transfer safeguards and subprocessor authorization together with the declared regional boundary.

6. Return, deletion and preservation boundaries

PRI-02 - Severity: High. Applies when personal data is processed.

For relationships processing personal data, the supplier must complete deletion of Northstar personal data within 30 calendar days after service termination or an authenticated deletion request, excluding documented preservation obligations and technically isolated backup cycles.

The comparable ordinary deletion-window declaration is the maximum ordinary deletion window after that trigger. It is not the lifetime of an active customer account, the age of an invoice or a general log retention period. A supplier stating a shorter operational target can be compared with the baseline only if the same trigger and scope apply. Northstar Privacy must seek clarification where a number refers to a different dataset or a different event. The review record preserves those different meanings until the supplier clarifies the applicable commitment.

Preservation obligations are documented exceptions with a stated basis, restricted purpose and review point. Technically isolated backups are outside the ordinary window only when their cycle and isolation are explained. Northstar Privacy must record what remains, why it remains and when the exception is reconsidered. A blanket phrase such as backups retained as needed does not establish a bounded exception. Data restored during recovery needs particular attention because a restore can reintroduce records previously removed from active service.

Secure return provides a useful exit route before deletion. The Northstar Business Owner must identify the recipient, expected format and integrity checks for exported records. Procurement must coordinate service termination so the receiving team can validate the export before access

closes. The supplier's description of return procedures can support the governance exit-plan control, but this document does not add another independent numbered obligation. Export availability and deletion completion are distinct events in the review timeline.

7. Assistance with individual requests

PRI-06 - Severity: Medium. Applies when personal data is processed.

For relationships processing personal data, the supplier must support Northstar with access, correction, deletion and export requests using the agreed authenticated request process.

The service description can show how records are located, corrected, removed or produced in an intelligible format. Assistance may use a product feature or an operational support route, provided the route addresses the actual dataset. Northstar Privacy must verify the identity and authority of the requester before forwarding instructions. A counterparty does not decide Northstar's response merely because it holds the records. The internal case record links the request, instruction and received assistance without exposing unnecessary personal information.

Request handling may reveal a mismatch between stated inventory and actual service behavior. For example, an export might omit event metadata that the service still associates with an account. Privacy must record the unresolved category and ask the Business Owner whether the service use remains appropriate. This assessment concerns completeness and meaning; the presence of a support email address alone does not demonstrate successful assistance.

8. Evidence, changes and exceptions

Northstar Privacy must retain dated evidence of the agreement, data-flow description, location statement, inventory and relevant deletion explanation. Redaction is acceptable when the remaining content supports the assessed claim. A file containing only a document title does not establish the content of its unavailable schedules. Supplier-authored summaries retain declaration provenance even when they describe an independent audit. Review notes identify which passages were inspected and what remains unresolved.

The Privacy Lead approves time-bound privacy exceptions with Security and Procurement consulted where their controls are affected. Northstar Third-Party Risk must record the affected requirement, reason, compensating measures, owner and expiry, and schedule reassessment before

that expiry. A review cannot erase an exception by changing a requirement quote. Policy revisions create a new version, while earlier analysis retains the original sources and decision basis. This separation makes the assessment useful for accountable operations without presenting a favorable status as legal certification.

Incorporated annex 4

Supplier Governance and Assurance Standard

Synthetic portfolio demonstration; not legal advice or a statement of any real organization's practices. Northstar Labs and all named suppliers are fictional.

Owner: Director of Procurement and Third-Party Risk. Approver: Northstar Risk Committee. Version: 1.0. Effective: 2026-09-15. Review due: 2027-09-15. Policy set: Northstar Labs Third-Party Assurance Standard.

1. Purpose, applicability and definitions

This document provides a consistent way to manage evidence, accountability and continuity across assessed supplier relationships. The four identified GOV controls are the supplier obligations in this document. Supporting paragraphs explain those controls or assign work to Northstar teams. They do not add unlisted counterparty requirements. The purpose is an accountable relationship decision: a favorable control review is neither a procurement authorization nor a certification of the supplier's security or financial condition.

The standard applies to all assessed suppliers. Enhanced continuity and exit duties apply when business criticality is high. Northstar's relationship record includes purpose, shared data, system access, personal-data processing and privileged access. These fields describe the proposed use rather than the supplier's entire business. A provider can be low criticality for a training demonstration and high criticality for an operational analytics service used in daily customer support. The classification belongs to the relationship and can change when the use changes.

A Business Owner is the Northstar person accountable for the service outcome. Third-Party Risk coordinates the assessment record; Procurement manages commercial arrangements; Security and Privacy interpret their respective controls. Supplier relationship owner means an accountable supplier role with an operational route for contact and escalation. A declaration is a supplier-authored statement. Independent evidence records

assessment activity outside the supplier's operating team and retains its own scope and coverage period.

2. Precedence and onboarding

The security, privacy and incident documents contain specialist controls. This document coordinates their review without replacing the specific encryption, deletion, hosting or notification rules. Northstar Procurement must escalate an apparent inconsistency between policy and contract to the relevant owner. A commercial deadline does not decide which interpretation is correct. The approved requirement version and the actual source documents remain attached to the assessment so a later reviewer can reconstruct the basis of the decision.

Northstar Third-Party Risk must classify the relationship with the Business Owner before selecting enhanced controls. The record explains the service dependency, alternatives, data sensitivity and access path. An empty context field is a request for clarification, not a negative answer. Security and Privacy must identify where their expertise is needed. For example, privileged support access can matter even when the primary application has few users, while a broad customer dataset can matter even when the service is easy to replace.

The Business Owner must verify that the named counterparty and product match the intended procurement. Group branding can conceal a different operating entity or a newly acquired platform. Procurement must identify the contracting entity and keep the relevant service schedule accessible. These internal checks precede human acceptance of the assessment; a supplier appearing in an existing vendor list does not establish approval for a new relationship.

3. Accountable supplier contact

GOV-01 - Severity: Medium. Supplier relationship accountability.

The supplier must name an accountable relationship owner and provide a maintained contact and escalation route for the assessed service.

The role can be supported by a shared mailbox and backup contact so an individual absence does not interrupt the relationship. Evidence can identify the service account team, operational support route and escalation path for unresolved assurance questions. A sales contact may coordinate discussion without having authority to resolve operational issues. Northstar's Business Owner must establish which route handles commercial matters and which route handles service incidents. The incident

document explains the timing of an initial incident notice.

Ownership records are useful when they connect a question to someone able to obtain an answer. Northstar Third-Party Risk must assign its own review actions rather than leaving an unanswered request indefinitely in a general inbox. If the supplier's named owner changes during review, the record identifies the new route and the date it was confirmed. This does not create a separate numerical response deadline; reviewers assess whether the proposed arrangement supports the actual service dependency.

4. Accurate responses and usable records

GOV-02 - Severity: Medium. Assurance response quality.

The supplier must provide accurate assurance responses with dated supporting evidence that identifies the assessed service, coverage period and known limitations.

A response distinguishes operational facts from future intentions. Planned remediation can explain an exception, but it does not establish that a control already operates. A dated statement includes the point in time or review period to which it applies. The upload timestamp records when Northstar received a file, not when the supplier last tested its content. Northstar reviewers must preserve that difference in notes and avoid treating a recent cover email as evidence that an old report is current.

Useful supporting material connects a claim to a system or process. A redacted approval record can illustrate access governance; a tested recovery record can illustrate restoration capability. Broad policy text usually establishes an intended process rather than proving consistent execution. Independent report excerpts can support specific claims within their scope. A supplier summary of that report remains a declaration unless the actual independent material is available and identified as such. Northstar Third-Party Risk must record these provenance limits explicitly.

Assurance responses sometimes contain contradictory values. Northstar reviewers must determine whether the statements concern the same field, service scope and period before describing them as a direct conflict. Different service tiers or coverage dates may instead indicate ambiguity. A request for clarification records both source passages and asks the supplier to identify the relevant boundary. Northstar Third-Party Risk preserves the competing evidence and the supplier's clarification in the review record.

5. Subcontractors and contractual boundaries

GOV-03 - Severity: High. Contractual flow-down.

The supplier must flow down the applicable Northstar service obligations to subcontractors performing those activities and retain accountability for their delivery.

A subcontractor can operate a material part of the service without holding a direct contract with Northstar. Flow-down connects the supplier's commitment to the dependency that performs the work. Evidence may describe the applicable contractual schedule, oversight route and handling of a missed duty. Northstar Procurement must assess whether the explanation covers the relevant activity instead of assuming that a general reference to standard terms addresses every service obligation.

The privacy inventory and change-notice control addresses subprocessors where personal data is involved. This governance control has a wider relationship boundary and does not duplicate the inventory requirement. Security duties, continuity arrangements or incident cooperation may matter even for a subcontractor that sees no personal data. Northstar Third-Party Risk must trace the dependency to the control it affects. A supplier's claim that a dependency is outside its direct operation does not alone resolve how the promised service outcome is delivered.

Changes in ownership, platform or subcontracting can make old evidence incomplete. Northstar's Business Owner must bring known material service changes to the review team, and Procurement must check whether a revised assessment is needed at renewal. The annual internal reassessment compares the actual current relationship with the approved version and any open exceptions. The supplier's accurate-response control remains the evidence obligation; this narrative does not introduce an additional unnumbered notification promise.

6. Continuity and exit for critical services

GOV-04 - Severity: High. Applies when business criticality is high.

For high-criticality services, the supplier must maintain a continuity plan and a tested exit plan covering recovery dependencies, Northstar data return and transition responsibilities.

Continuity concerns restoring an acceptable service after disruption. Exit concerns moving away from the service in an orderly way. A restore exercise can show that one component is recoverable without demonstrating

a complete transition to another provider. Evidence for this control can describe exercise scope, participating roles, observed limitations and tracked actions. Northstar's Business Owner must compare the demonstrated outcome with the service dependency rather than treating the existence of a plan as proof that any outage can be tolerated.

A useful exit plan identifies export formats, access needed during transition, validation by the receiving team and the boundary between return and deletion. A tested sample can expose incomplete fields or undocumented transformations before a real termination. The privacy document defines the ordinary deletion window; it does not require that records disappear before Northstar can validate an agreed return. Procurement and Privacy must coordinate the contract schedule with operational sequencing so those two activities do not contradict each other.

Continuity evidence can also show dependency risks, including a shared identity service, an external operator or unavailable specialist staff. Northstar Third-Party Risk must record where an exercise used simulation rather than a real recovery. A desktop walkthrough is useful for role coordination but has a different evidential value from a tested restore. Reviewers can accept different evidence types for different questions while retaining the limit of what was actually demonstrated.

7. Financial and operational escalation

Northstar Procurement must route credible concerns about service continuity, organizational change or commercial instability to the Business Owner and Third-Party Risk. The objective is to understand service dependency and available alternatives, not to assign an unsupported financial health score. A security questionnaire cannot establish solvency. Where financial expertise is needed, the internal review records that dependency and the specialist decision instead of extending a control finding beyond its evidence.

The Business Owner must maintain a practical route for operating while an assurance question remains unresolved. Possible actions include limiting the proposed scope, seeking additional evidence or preparing an alternative service. These are internal decisions with commercial and operational consequences. The assessment record identifies the reviewer's decision and rationale separately from residual risk and evidence gaps. A request for more information remains a valid outcome when the available material cannot support a defensible acceptance decision.

8. Exceptions, approval and monitoring

Northstar Third-Party Risk must maintain an exception record with the affected requirement, justification, compensating controls, accountable owner and expiry. Procurement coordinates governance exceptions; Security and Privacy approve exceptions in their domains. Reassessment is scheduled before expiry and after a material change. A previous acceptance is evidence of an earlier decision, not permission to assume that a changed service still meets the same controls. Unresolved items remain visible through renewal and transition.

Northstar reviewers must keep original source versions, locations and evidence classifications with the assessment. Corrections create a new review basis instead of rewriting a historical report. The Business Owner approves the business decision through the authorized workflow, while any instruction sent to an outside party follows the appropriate communication authorization. This separation prevents an information request or an external instruction from being mistaken for permission to use a supplier. The record supports learning and accountable decisions without claiming universal supplier assurance.

Executed change schedule CB-7

This schedule is signed with the main agreement and applies only to production payroll. It prevails over inconsistent general deadlines for the named obligations. All other Northstar supplier standards continue to apply. The parties deliberately retain the original provisions above so that the reader can identify the baseline and the exact amendment rather than treating both numbers as unresolved contradictions.

CB-7 replaces the ordinary 30-day removal deadline with a 14-day deadline for production payroll records. The trigger remains service termination. Technically isolated recovery copies follow a 60-day expiry cycle and cannot be used for ordinary payroll processing during that period. If a restoration reintroduces records previously removed, the removal instructions are reapplied before normal access resumes. A documented preservation hold is separately identified by record category and custodian; it is not an indefinite exception for the whole tenant.

CB-7 permits a named Canadian specialist to access masked payroll troubleshooting records for an approved incident task, overriding the earlier EEA-only support restriction for that task alone. The specialist cannot export full salary files. Access requires a task owner, approval and session record. This authorization does not move primary storage or routine calculation outside Germany and Ireland. Additional overseas access requires a new approved change.

Cedar must deliver the exit export within seven calendar days after Northstar's authenticated request. The seven-day delivery window does not extend the amended 14-day removal deadline. If validation cannot finish within that interval, the parties must record a scoped instruction and preservation basis rather than silently continuing ordinary processing. The final receipt distinguishes successful delivery, customer validation and deletion completion.